

Complete Project Documentation

Capstone Project Coursework — Group Capstone Project, Individual Submission

University of Ghana, Department of Computer Science

Group Name: Architects

Project Title: HealthEasy-G HMS

Student:

Ernest Nketia Asubonterng (Lead)

Student ID: 22424715

Software architecture, Ollama clinical assistant and GSTG rule engine, Next.js App Router,

PostgreSQL and Prisma, HeFRA/GHS compliance, multi-facility management

Table of Contents

1. Project Title and Group Information.....	6
1.1 Group Members and Contributions	6
1.2 Note on This Submission	7
1.3 Companion Documents.....	7
2. Introduction and Background	7
2.1 Context.....	7
2.2 Why This Matters	8
2.3 Project Origin.....	8
3. Problem Statement.....	8
3.5 Statement.....	9
4. Aim and Objectives.....	9
4.1 Aim	9
4.2 Objectives	10
5. Stakeholder Analysis	11
5.1 Register	11
5.2 How Stakeholders Shaped the System.....	12
6. Requirements Gathering and Analysis.....	12
6.1 Techniques	12
6.2 Requirements Conflicts Resolved.....	13
6.3 Prioritisation.....	13
7. Software Requirements Specification.....	13
7.1 Functional Requirements — Summary.....	13
7.2 Non-Functional Requirements — Summary	15
7.3 Constraints and Assumptions.....	15

8. System Analysis.....	16
8.1 Analysis of the Existing Process.....	16
8.2 Analysis of the Proposed System.....	16
8.3 Feasibility.....	17
9. System Design	18
9.1 Design Principles	18
9.2 Design Artefacts Produced	18
10. Architecture.....	19
10.1 Style	19
10.2 Why Not Microservices	19
10.3 Layers.....	19
10.4 Security Architecture	19
10.5 Technology Choices.....	20
11. Database and Data Design	21
11.1 Model	21
11.2 Design Decisions	21
11.3 Migration Strategy	22
12. User-Interface Design	22
12.1 Design Language	22
12.2 Interaction Principles	22
12.3 Responsiveness and Accessibility.....	23
13. Implementation	23
13.1 Scale.....	23
13.2 Implementation of Key Mechanisms	23
13.3 Code Organisation	24

14. Testing and Quality Assurance	25
14.1 Results.....	25
14.2 The Access-Control Evidence.....	26
14.3 Defects	26
15. Deployment.....	26
15.1 Deployed System	26
15.2 Pipeline	27
15.3 Configuration	27
15.4 Credential Handling.....	27
16. User Manual.....	27
17. System Administration and Maintenance Guide	27
18. Security Considerations	28
18.1 Threat Model.....	28
18.2 Compliance with the Data Protection Act, 2012	29
18.3 Residual Risks.....	29
19. Challenges and Solutions.....	30
20. Limitations	31
21. Maintenance Strategy.....	33
22. Future System Evolution and Enhancements	33
23. Conclusion	34
24. References.....	36
24.1 Regulatory and Clinical Sources.....	36
24.2 Software Engineering Sources	37
24.3 Technologies, Frameworks and Services Acknowledged	38
25. Appendices.....	40

Appendix A — Repository Structure.....	40
Appendix B — API Endpoint Reference.....	41
Appendix C — Role and Permission Summary	42
Appendix D — Environment Variables.....	43
Appendix E — Commands	44
Appendix F — Test Execution Summary	45
Appendix G — Live Database Contents at Submission	46

1. Project Title and Group Information

Project title: HealthEasy — HealthEasy-G Hospital Management System

Group name: Architects

Course: CSCD602 Advance Software Development — Capstone Project

Department: Computer Science

Institution: University of Ghana **Session:** Semester 2, 2026

Live application: <https://healtheasy-g.vercel.app>

Source code repository: <https://github.com/NketiaAsubontengErnest/HealthEasy-G>

Examiner credentials: supplied in Links.txt with this submission

1.1 Group Members and Contributions

No.	Group Member	Student ID	Major Contribution
1	Ernest Nketia Asubonterng	22424715	Lead System Architect & AI Integrator. Layered system architecture; server-side authentication and role-based access control; PostgreSQL schema, migrations and the Prisma data-access layer; the Ollama clinical decision-support assistant and its GSTG fallback; multi-facility management; automated test suite and continuous integration; deployment.
2	Nana Kwabena Asare	22424817	Clinical EMR consultation module and the ICD-10 diagnosis engine.
3	Casper Kosi Asense	22425080	Master Patient Index, Ghana Card and NHIS validation, duplicate prevention.
4	Aubrey Owusu Amoah	22424666	PACS radiology ordering, reporting workflow and diagnostic worklists.

5	Thomas Nii Armah Okai	22425782	Pharmacy FEFO stock control and transactional prescription dispensing.
6	Abubakari Zubeiru	22425115	Inpatient bed management, medication administration record, and DPC audit-log compliance.
7	Frank Tandoh	22425049	Responsive layouts, design system, theming and accessibility.

1.2 Note on This Submission

This document is submitted individually by **Ernest Nketia Asubonternng (22424715)** in accordance with the individual submission requirement. The software is the group's work; the contribution recorded above for this student is the architecture, the security model, the data layer, the clinical AI integration, the test suite and the deployment.

1.3 Companion Documents

Document	Contents
SRS.pdf	Software Requirements Specification
Design_Documentation.pdf	Architecture and all design artefacts
Testing_Report.pdf	Test strategy, executed evidence and defect log
User_Manual.pdf	Role-by-role operating instructions and administration guide
Maintenance_and_Evolution.pdf	Maintenance strategy and evolution roadmap
README.pdf	Examiner quick-reference guide
Links.txt	URLs and verified access credentials

2. Introduction and Background

2.1 Context

Healthcare delivery in Ghana is organised through the Ghana Health Service, regulated for facility standards by the Health Facilities Regulatory Agency, financed in substantial part

through the National Health Insurance Scheme, and reported nationally through the District Health Information Management System. A hospital therefore has obligations in four directions at once: to its patients, to its regulator, to its payer, and to the national statistical system.

Most district and regional facilities meet these obligations on paper. Patient records are folders in a registry. Laboratory requests are slips carried by hand. NHIS claims are transcribed from folders onto claim forms. DHIMS2 returns are counted from attendance registers at the end of the month.

2.2 Why This Matters

Paper does not fail dramatically; it fails quietly and constantly. A folder that cannot be found becomes a second folder. A result slip that goes astray becomes a repeated test. An allergy recorded on the first visit is invisible on the third if the first folder is the one that was mislaid. A claim transcribed by hand acquires a transcription error and is rejected, and the facility absorbs the cost.

Each of these is individually small. Collectively they consume clinical time, waste consumables, delay treatment, and lose revenue the facility is entitled to.

2.3 Project Origin

HealthEasy-G was undertaken as the CSCD602 capstone project by group Architects. The brief required a complete, deployed, working system rather than a prototype — which shaped the project decisively. A prototype can demonstrate a screen; a working system must decide what happens when two clerks register the same patient at the same moment, when a pharmacist dispenses from a batch another pharmacist has just emptied, and when a system administrator opens a patient's record.

3. Problem Statement

A patient's record does not follow the patient.

Each department in a Ghanaian hospital maintains its own account of a patient's care, and the accounts are joined only by paper carried between them or by the patient's own memory. Four consequences follow, and they are the problems this system addresses:

3.1 One patient becomes several records. With no reliable unique identifier enforced at registration, a patient attending three times can accumulate three folders. Clinical history fragments across them. An allergy recorded once is not seen again.

3.2 Information is retyped at every hand-off. The name written at registration is written again on the triage sheet, again on the laboratory request, again on the prescription and again on the claim form. Every transcription is an opportunity for error, and the errors are detected — if at all — by the party that rejects the claim.

3.3 Authority is a matter of custom, not enforcement. Who may see a folder, who may release a result, who may authorise a refund: these are conventions. A paper system cannot enforce them, and a computer system that only hides menu items has not enforced them either.

3.4 Statutory reporting is reconstructed rather than derived. DHIMS2 returns and NHIS claims are compiled at month end by counting registers. The figures are as accurate as the counting, and they cannot be checked against anything.

3.5 Statement

Ghanaian health facilities lack an integrated system that maintains a single authoritative record per patient across all departments, enforces professional authority at the point of access rather than by convention, and derives statutory and insurance reporting from clinical activity rather than from manual recounting.

4. Aim and Objectives

4.1 Aim

To design, implement, test and deploy a working Hospital Management System that maintains one authoritative record per patient across every department of a Ghanaian health facility, with professional authority enforced by the system and statutory reporting derived from clinical activity.

4.2 Objectives

No.	Objective	Achieved by	Evidence
O1	Establish a Master Patient Index that prevents duplicate records	Ghana Card uniqueness enforced at the database and rejected with an identifying message at the API	TC-PAT-02
O2	Carry one record through every department without retyping	Consultation orders fan out automatically into laboratory, pharmacy, billing and claims	TC-INT-01
O3	Enforce role-based authority on the server	19 roles, 62 permissions, a fail-closed policy applied by withAuth to all 24 endpoints	7.2 of the Testing Report
O4	Satisfy Ghanaian regulatory requirements in the system's behaviour	HeFRA licence tracking, NHIA G-DRG claim structure, DHIMS2 computation, DPC access restriction and audit trail	TC-RPT-01...05, TC-SEC-16
O5	Guarantee that clinical and stock operations are atomic	Transactional dispensing with conditional stock decrement; transactional claim batching	TC-INT-02, TC-INT-03
O6	Provide clinical decision support that is safe when it fails	Ollama assistant restricted to stocked medicines, allergy conflicts re-derived locally, deterministic GSTG fallback	TC-AI-02...04
O7	Operate in facilities with unreliable connectivity	Identical schema and seed on local or cloud PostgreSQL, selected by configuration	6 datasource tests
O8	Deliver a deployed system, not a prototype	Live on Vercel with a managed database, publicly reachable	TC-SYS-01

O9	Demonstrate engineering quality	53 automated tests, strict typing, CI on every push, versioned migrations, documented defect log	Testing Report
----	---------------------------------	--	----------------

5. Stakeholder Analysis

Presented in full in the SRS, 3. Summarised here.

5.1 Register

Stakeholder	Type	Principal interest	Influence
Patients	External beneficiary	Accurate records, shorter waits, correct bills	Low direct
Clinical staff	Internal primary user	A complete record, minimal typing	High
Front-desk staff	Internal primary user	Fast registration, duplicate prevention	High
Diagnostic staff	Internal primary user	Clear worklist, traceable specimens	Medium
Pharmacy staff	Internal primary user	Accurate stock, safe dispensing	Medium
Cashiers and finance	Internal primary user	Correct charges, reconciled collections	Medium
Claims officers	Internal primary user	Claims that pass NHIA vetting	High
Hospital leadership	Internal decision maker	Operational visibility, compliance	High
System auditor	Internal governance	A complete, tamper-evident trail	Medium

Ghana Health Service	External regulator	DHIMS2 returns	High
NHIA	External payer	Valid, well-formed claims	High
HeFRA	External regulator	Facility licensing compliance	High
Data Protection Commission	External regulator	Lawful processing of health data	High

5.2 How Stakeholders Shaped the System

Regulator requirements were treated as **constraints**, not features — the DPC access restriction is enforced in code and cannot be configured away. Clinical staff shaped the **interaction design**: screens are task-shaped rather than table-shaped, and the information a clinician needs before writing (allergies, chronic conditions, last observations) is presented before the writing area. Claims officers shaped **validation**: the audit flags raised on a claim correspond to the reasons NHIA rejects claims.

6. Requirements Gathering and Analysis

Presented in full in the SRS, 4.

6.1 Techniques

As an academic capstone with no commissioning client, requirements were elicited from documentary and observational sources: analysis of GHS operating procedures, NHIA claim structure and rejection criteria, DHIMS2 return forms and the Data Protection Act; end-to-end modelling of the outpatient journey; decomposition of the paper forms currently in use; decomposition of hospital staffing into roles and their scope of practice; failure analysis of known paper-system failure modes; and iterative prototyping.

6.2 Requirements Conflicts Resolved

Four conflicts required explicit resolution rather than compromise:

1. **Administrator capability versus data protection.** Resolved by barring the Super Admin from clinical data at the server and providing aggregate statistics instead.
2. **Registration speed versus duplicate prevention.** Resolved by enforcing Ghana Card uniqueness absolutely while providing an emergency fast-track path for unidentified patients.
3. **Prompt result entry versus safe result release.** Resolved by separating recording from verification into two permissions.
4. **Offline operation versus centralised data.** Resolved by supporting local and cloud databases with an identical schema.

6.3 Prioritisation

MoSCoW. All 61 *Must* and 14 *Should* requirements are implemented; 3 of 9 *Could* requirements are implemented and the remainder appear in the roadmap.

7. Software Requirements Specification

The complete SRS is submitted as a separate document (SRS.pdf). Summarised here.

7.1 Functional Requirements Summary

Group	Requirements	Coverage
Authentication and session (AUTH)	9	Password authentication, signed sessions, token rejection, enumeration resistance, throttling, expiry
Patient administration (PAT)	8	Registration, duplicate prevention, MRN allocation, NHIS capture, search, emergency fast-track, automatic queue routing
Queue and flow (QUE)	5	Per-department tickets, derived waiting time, priority, state transitions

Triage (TRI)	5	Observations, BMI, ESI acuity, derived alerts, session attribution
EMR (EMR)	7	Full clinical note, ICD-10, history presentation, ordering, order fan-out, attribution, sick leave
Laboratory (LAB)	6	Test catalogue, barcoding, status progression, verification authority, result parameters, catalogue-derived metadata
Radiology (RAD)	4	Order capture, accession numbering, separation of performing from reporting, critical findings
Wards (WRD)	5	Bed register, states, double-assignment refusal, medication chart, mandatory omission reason
Pharmacy (PHM)	7	Batch stock, FEFO ordering, atomic dispensing, quantity and expiry refusal, controlled substances, counselling
Billing (BIL)	7	Itemised invoices, server-recomputed totals, NHIS exemption, payment methods, overpayment refusal, refund authority, receipting
Claims (CLM)	7	Claim generation, record-sourced demographics, audit flags, computed totals, batching, atomic stamping, lifecycle
Inventory (INV)	3	Store items, derived status, optional expiry
Reporting (RPT)	5	DHIMS2 computation, manual figures, aggregate statistics, HeFRA and staff licence tracking
Security (SEC)	8	RBAC, server enforcement, fail-closed

		policy, DPC restriction, session attribution, audit trail, validation, credential protection
Clinical AI (AI)	6	Context-aware suggestion, stock restriction, allergy re-checking, deterministic fallback, source disclosure, advisory framing

7.2 Non-Functional Requirements Summary

Category	Key requirements
Performance	Page load ≤ 2 s; API read ≤ 800 ms; login ≤ 1.5 s; 50 concurrent sessions
Security	HTTPS; httpOnly/SameSite/Secure cookies; HMAC-SHA256 with a ≥ 32 -character secret; constant-time comparison; bcrypt ≥ 10 rounds; no credentials in version control; parameterised queries
Reliability	99% availability in operating hours; offline operation; atomic multi-table operations; no silent write failure
Usability	Two clicks to any permitted module; 360–2560 px; actionable errors; explained denials; light default with dark option; reduced-motion support
Maintainability	Strict TypeScript; single-point policy, conversion and date handling; automated tests; CI; versioned migrations
Portability	Node 20+/PostgreSQL 14+; identical code for local and cloud; current and previous major browsers
Compliance	Act 843; NHIA G-DRG; DHIMS2; HeFRA; Ghana Standard Treatment Guidelines

7.3 Constraints and Assumptions

Ten constraints are recorded in the SRS, of which the most consequential are: live NHIA and NIA verification requires an accredited integration agreement unavailable to a student project (C-03); DICOM storage is beyond the available infrastructure (C-04); the clinical assistant must not depend on a paid external API (C-05); and health data is subject to Act 843, making server-enforced access control and an immutable audit trail mandatory rather than optional (C-09).

8. System Analysis

8.1 Analysis of the Existing Process

The outpatient journey was traced end to end and each hand-off examined for the information it consumes and produces.

Stage	Input	Output	Failure mode in the paper system
Arrival	Patient, possibly a card	Folder retrieved or created	Folder not found → duplicate created
Triage	Folder	Observations on a sheet	Sheet separated from folder
Consultation	Folder, triage sheet	Notes, diagnosis, orders	Previous history unavailable
Laboratory	Request slip	Result slip	Slip lost; result never reaches the clinician
Pharmacy	Prescription	Medicine, stock reduction	Stock ledger updated separately or not at all
Cashier	Charges, possibly verbal	Payment, receipt	Charges missed → revenue lost
Claims	Folder, at month end	Claim form	Transcription error → rejection
Reporting	Registers, at month end	DHIMS2 return	Miscount, unverifiable

The pattern is consistent: **information is lost at hand-offs**, and every failure is a failure of continuity rather than of any individual step.

8.2 Analysis of the Proposed System

The proposed system replaces the hand-off with a shared record. The analysis that follows from this is that the critical design problems are not the screens but the **junctions**:

Junction	Design problem	Resolution
Registration → identity	Two clerks registering the same person simultaneously	Database uniqueness on Ghana Card; candidate-and-retry MRN allocation
Consultation → departments	One clinical action must produce work in three departments without partial completion	Sequential creation with individual failure reporting; the encounter is never lost
Dispensing → stock	Medicine handed out and stock reduced must be one event	Single transaction with a conditional decrement
Claim → batch	A claim must not be submitted twice	Batch creation and claim stamping in one transaction
Any access → authority	Who may do what must be decided somewhere that cannot be bypassed	Server-side policy applied to every request

8.3 Feasibility

Dimension	Assessment
Technical	Feasible. Next.js, PostgreSQL and Prisma are mature and well documented. The one genuinely uncertain element — clinical AI — was made optional by design, with a deterministic fallback.
Operational	Feasible with reservations. The system assumes electricity, a local network and individual staff accounts. Offline database operation addresses connectivity but not power.
Economic	Feasible. The entire stack runs on free or low-cost tiers; the clinical assistant deliberately avoids a paid API.
Legal	Feasible. Act 843 obligations are addressed by design. Live national-system integration is not, and is scoped out explicitly.

Schedule	Feasible within one semester for the scope defined; larger modules were consciously deferred to the roadmap rather than half-built.
-----------------	---

9. System Design

Presented in full in Design_Documentation.pdf. Summarised here.

9.1 Design Principles

1. **The server is the only authority.** Anything the browser sends can be forged.
2. **One boundary per concern.** Policy, conversion and date handling each live in one file.
3. **Fail closed.** An undeclared policy denies; an unknown enum falls back to the safest value.
4. **Derive rather than store.** A stored status is a status that can drift from what it describes.

9.2 Design Artefacts Produced

Artefact	Location
Layered architecture diagram	Design Documentation 2.2
Request lifecycle sequence	2.4
Deployment topology	3.1
Use-case diagrams (2)	4.1, 4.2
Use-case specifications (2)	4.3, 4.4
Domain class diagram	5.1
Security class diagram	5.2
Sequence diagrams (4)	6
Activity diagrams (2) and a state diagram	7
Entity-relationship diagram	8.1
Data dictionary	8.3
Component diagram	9.1
Wireframes (3)	10.3–10.5

10. Architecture

10.1 Style

A **layered architecture within a serverless deployment**. Next.js App Router provides the presentation and application layers in one deployable unit; Prisma provides data access over PostgreSQL.

10.2 Why Not Microservices

The domain is a single bounded context with heavily interconnected data. Splitting patient, clinical, pharmacy and billing into separate services would introduce distributed transactions across boundaries that must be atomic — dispensing with stock deduction, batching with claim stamping — in exchange for scaling flexibility this workload does not require. Service extraction is placed last in the scalability path for exactly this reason.

10.3 Layers

Layer	Components	Responsibility
Presentation	33 pages, HMSContext, api-client	Render state, collect input, explain outcomes
Security perimeter	proxy.ts, api-guard.ts, api-policy.ts, session.ts	Establish identity; permit or deny
Application	24 route handlers	Orchestrate use cases
Domain services	adapters.ts, validation.ts, sequence.ts, auth.ts	Enforce invariants
Data	prisma.ts, resolve-datasource.ts, PostgreSQL	Persist and retrieve

10.4 Security Architecture

Four layers, each of which must pass before a request does any work:

1. **proxy.ts** verifies the signed session at the edge and enforces each role's permitted routes. Unauthenticated API requests receive 401; page requests are redirected.

2. **withAuth** consults the policy table for the specific method and path. An undeclared combination is denied.
3. **The route handler** performs its own domain-specific authority checks where the action requires more than endpoint access — releasing a laboratory result, issuing a radiology interpretation, reducing a settled payment.
4. **The database** enforces the final invariants: uniqueness, referential integrity and enum validity.

10.5 Technology Choices

Concern	Choice	Principal reason
Framework	Next.js 16 App Router	One deployable; server components keep data access off the client; native middleware for a perimeter
Language	TypeScript strict	Compile-time detection of shape mismatch — the defect class that most damaged the early codebase
ORM	Prisma 5	Generated types; parameterised queries; versioned migrations
Database	PostgreSQL	Relational integrity, transactions, native dates and enums, JSON where structure genuinely varies
Session	HMAC-SHA256 via Web Crypto	Stateless, verifiable at the edge, identical code in both runtimes, no dependency
Passwords	bcrypt (10 rounds)	Deliberate slowness
Clinical AI	Ollama with rule-engine fallback	No paid API; works offline; the fallback is deterministic and auditable
Testing	Node built-in runner + tsx	No additional dependency
Hosting	Vercel + Neon	First-class Next.js support; managed PostgreSQL

11. Database and Data Design

11.1 Model

Nineteen Prisma models over PostgreSQL. Patient and UserStaff are the two hubs: nearly every clinical record references a patient, and nearly every action references the staff member who performed it.

11.2 Design Decisions

Uniqueness as the integrity mechanism. ghanaCardNo, mrn, staffId, email, batchNumber, barcodeNo, invoiceNumber, claimNumber and pacsAccessionNo carry unique constraints. Document numbers are allocated by generating a candidate and letting the unique index settle collisions, with retry — because count() + 1 produces duplicates under concurrency and reuses numbers after deletion (defect D-07).

Native date and time types. Sixteen columns across nine tables are PostgreSQL DATE or TIMESTAMP. They were initially text, which made every comparison lexical — '2026-9-1' sorts after '2026-10-01' — so expiry checks and month filters silently returned wrong rows (defect D-05). Migration 20260814000000_dates_and_session_security converts existing rows in place with explicit USING casts rather than dropping columns.

Enumerations in the database. Seven enums, so an invalid value cannot be stored at all.

JSON where structure genuinely varies. icdDiagnoses, orders, results and lineItems are lists whose length and shape vary per record and which are always read whole. Normalising them would add four tables and four joins for no query benefit.

Cascade on patient deletion, but not for audit. Clinical children cascade; audit entries do not. The trail must outlive the record it describes.

Derived, not stored. Stock status, waiting minutes, licence expiry status and DHIMS2 attendance are computed at read time.

11.3 Migration Strategy

Schema changes are versioned SQL under prisma/migrations/, applied in order, never edited once released, and written to convert data in place.

12. User-Interface Design

12.1 Design Language

Aspect	Decision
Default theme	Light, with a persisted dark option
Public site typography	Newsreader (serif display) with Manrope (sans body)
Portal typography	Manrope, optimised for dense tabular reading
Brand colour	Deep clinical green #0d6b4e, used as a single accent
Status colours	Amber waiting, green in-progress or complete, rose critical, stone neutral
Layout	Sidebar navigation, sticky header, 12-column responsive grid
Density	High on worklists, low on data entry
Motion	Scroll reveals on the public site only, suppressed under reduced-motion

12.2 Interaction Principles

Show the role's work, not the system's capabilities. The sidebar lists only permitted modules.

Present what is needed before the field that needs it. Allergies and chronic conditions appear above the prescribing area, not on a separate tab.

Explain refusals. A denial names the active role, the missing authority and the constraint being enforced.

Never fail silently. Every rejected write raises a dismissible alert stating the action and the reason.

12.3 Responsiveness and Accessibility

Layouts adapt across 360–2560 px; wide tables scroll within their own container so the page body never scrolls horizontally. Semantic elements, keyboard operability, aria-label on icon-only controls, role="alert" on error regions, WCAG AA contrast in both themes, and prefers-reduced-motion support.

13. Implementation

13.1 Scale

Measure	Value
TypeScript / TSX	22,232 lines
Prisma models	19
API route handlers	24
Application pages	33
Roles	19
Permissions	62
Automated tests	53

13.2 Implementation of Key Mechanisms

Authentication. POST /api/auth/login looks the account up, compares with bcrypt, refuses non-Active accounts, records the attempt in the audit trail either way, and issues an HMAC-SHA256 signed token in an httpOnly cookie. Unknown addresses and wrong passwords receive an identical response.

Authorisation. API_POLICY declares, for each path and method, either “any authenticated session”, “one of these roles”, or “one of these permissions”. withAuth consults it before the handler runs and denies anything undeclared. Reads use role lists because a data-protection boundary must be auditable at a glance; writes use permissions because they correspond to professional authority.

Identity attribution. Every write takes the acting identity from the verified session. There is no code path by which a request body can name the author of a record.

Atomicity. Dispensing opens a transaction, verifies existence, sufficiency and expiry, writes the dispense record, then decrements conditionally (WHERE quantityInStock >= n). If a concurrent dispense drained the batch, the update matches nothing and the transaction rolls back rather than driving stock negative.

Shape translation. adapters.ts converts Prisma rows to client records at the API boundary. IN_CONSULTATION becomes In Consultation; bedType becomes type; totalClaimGhc becomes totalClaimAmountGhc.

Error handling. ApiError carries the HTTP status and the server's reason. A 403 on a collection read is treated as an empty collection — a cashier legitimately has no laboratory worklist — while every other failure surfaces to the user.

Clinical decision support. The assistant is given the patient's diagnoses, observations, allergies, chronic conditions, results, history and live stock. Its output is filtered against stock so a hallucinated medicine cannot reach a prescribing screen, allergy conflicts are re-derived locally, and a timeout triggers the GSTG rule engine. The response states which produced it.

13.3 Code Organisation

src/

app/

(DashboardLayout)/ 33 pages, grouped by module

api/ 24 route handlers

components/ shared and public-site components

lib/

session.ts token signing and verification

api-guard.ts withAuth

api-policy.ts access declarations

api-client.ts typed browser HTTP

adapters.ts storage ↔ presentation conversion

validation.ts input rules

sequence.ts document numbering
rate-limit.ts sign-in throttling
types/ domain and RBAC types
proxy.ts security perimeter
prisma/
schema.prisma 19 models
migrations/ versioned SQL
seed.ts complete seed
tests/ 53 automated tests
scripts/ database and documentation tooling

14. Testing and Quality Assurance

Presented in full in [Testing_Report.pdf](#). Summarised here.

14.1 Results

Level	Method	Result
Unit	53 automated tests, node:test	All pass
Static analysis	tsc --noEmit, strict	Zero errors across 22,232 lines
Integration	Route handler with live PostgreSQL	All pass
System	HTTP against the deployed instance	All pass
Security	Session forgery, access matrix, injection, exposure	All pass
Functional	Every <i>Must</i> requirement	All pass
Usability	Task completion and accessibility	All pass
Performance	Measured against the deployed instance	Two endpoints marginal (D-09)
Acceptance	Role-based scenarios	Accepted

14.2 The Access-Control Evidence

The central claim of the system — that authority is enforced by the server — is demonstrated by a matrix of 15 endpoints against 6 roles, executed with curl against the live deployment. It shows the Super Admin receiving 403 on every identifiable clinical collection while retaining access to aggregate statistics and the audit trail; the Cashier reaching billing and claims but no clinical data; and the Laboratory Technician reaching diagnostics but neither clinical notes nor finance.

14.3 Defects

Seventeen defects were identified: 3 Critical, 6 High, 6 Medium, 2 Low. Sixteen are closed. The one open defect is a measured performance shortfall on two endpoints with a diagnosed cause and a scheduled remedy.

The most instructive was **D-06**: `VERIFY_LAB_RESULTS` existed in the permission catalogue but was granted to no role, so no user in the system could release a laboratory result. It was found by an automated test asserting a property of the policy itself — that every permission referenced is held by somebody — rather than by any behavioural test.

15. Deployment

15.1 Deployed System

Item	Value
Live application	https://healtheasy-g.vercel.app
Admin URL	Same portal; the interface adapts to the role
Platform	Vercel (Edge middleware + Node.js serverless functions)
Database	Neon serverless PostgreSQL
Repository	https://github.com/NketiaAsubontengErnest/HealthEasy-G
Credentials	Links.txt, supplied with this submission

15.2 Pipeline

git push → GitHub → CI (typecheck, test, build against PostgreSQL)
→ Vercel build (prisma generate && next build)
→ Deployment

15.3 Configuration

Runtime configuration is by environment variable: DATABASE_TARGET selecting local or cloud, the two connection strings, SESSION_SECRET, session lifetime, and optional Ollama settings. The application refuses to sign sessions in production with a secret shorter than 32 characters.

15.4 Credential Handling

.env has never been committed — verified by git log --all -- .env. Examiner credentials are supplied only in Links.txt, which is excluded by .gitignore. Connection strings are redacted before any logging.

16. User Manual

Presented in full in User_Manual.pdf, covering sign-in, navigation, and step-by-step instructions for each of the 19 roles, followed by an administration guide (installation, online/offline operation, account management, routine maintenance, backup and recovery, troubleshooting).

Two points from it are worth repeating here because they are commonly mistaken for faults:

- **Modules missing from the sidebar** are modules the signed-in role may not use.
- **The administrator cannot open patient records.** This is the Data Protection Act restriction being enforced, not a malfunction.

17. System Administration and Maintenance Guide

Presented in full in User_Manual.pdf Part III and Maintenance_and_Evolution.pdf.

Task	Frequency
Verify backups	Daily
Review the audit trail	Weekly
Dependency audit	Weekly, automated
Review licence expiry	Monthly
Apply dependency updates	Monthly
Rotate the session secret	Quarterly
Rehearse a restore	Quarterly
Review the access policy	Quarterly
Apply security patches	On release

18. Security Considerations

18.1 Threat Model

Threat	Mitigation
Credential theft	bcrypt hashing; no plaintext storage or transmission; throttled sign-in
Session forgery	HMAC-SHA256 signature with constant-time comparison; verified on every request
Privilege escalation	Role read from the signed token, never from the client; policy fails closed
Account enumeration	Identical response for unknown address and wrong password
SQL injection	Parameterised queries through Prisma throughout
Unauthorised data access	Server-side policy on all 24 endpoints; DPC restriction on the administrator
Repudiation	Audit trail attributing every action to a session identity
Data tampering	Server recomputes financial totals; claim demographics read from the patient record

Credential exposure	passwordHash excluded by explicit select; connection strings redacted; .env untracked
Weak configuration	Production refuses a session secret under 32 characters

18.2 Compliance with the Data Protection Act, 2012

Principle	Implementation
Lawful, minimal processing	Registration captures only what care and claims require
Purpose limitation	Role-based access confines data to those with a care or administrative need
Accuracy	Single record per patient; demographics sourced from the record, not retyped
Security	Encryption in transit, hashed credentials, server-enforced access control
Accountability	Immutable audit trail of every access and change
Consent	Recorded at registration

The administrator restriction is the clearest expression of this. It would have been easier to grant the Super Admin unrestricted access, and every conventional admin panel does. Section 20 of the Act limits access to those with a legitimate need, and a technical administrator has none for clinical records. The restriction is enforced in code, tested, and demonstrated in the live access matrix.

18.3 Residual Risks

Risk	Status
Process-local rate limiting	Weakened across multiple instances; shared store planned
Shared demonstration password	Acceptable for seeded demonstration data; forced change planned before production
No penetration test	Recommended before any production deployment
No audit archival	Table grows unbounded; retention policy planned

19. Challenges and Solutions

Challenge	Response	What it cost, and what it bought
The system looked complete but was not. Screens rendered convincingly from ~900 lines of fabricated client-side data that masked empty tables and a storage/presentation mismatch.	Removed all fabricated data; built a single adapter layer; seeded every table; added 11 conversion tests.	Cost: a large refactor mid-project. Bought: certainty that what is on screen is in the database.
Authentication existed but could be bypassed. Three separate fallbacks signed users in without a password; identity lived in localStorage where any user could edit their own role.	Rebuilt as signed httpOnly sessions with a server perimeter and a fail-closed policy on all endpoints.	Cost: the largest single piece of work. Bought: the system's central claim being true.
Reconciling administrator convenience with the Data Protection Act.	Barred the Super Admin from clinical data at the server; added an aggregate statistics endpoint so oversight survives without identifiers.	Cost: an extra endpoint and a less conventional admin experience. Bought: demonstrable compliance.
Dates were text. Lexical comparison meant expiry checks and month filters silently returned wrong rows.	Migrated 16 columns to native types with in-place conversion; centralised parsing and formatting; rejected malformed input at the boundary.	Cost: a schema migration touching nine tables. Bought: comparisons that are correct.
Concurrency in dispensing	Transactional dispensing with	Cost: more careful handlers.

and numbering. Read-then-write stock deduction lost units; count() + 1 numbering produced duplicates.	a conditional decrement; candidate-and-retry numbering against the unique index.	Bought: correctness under simultaneous use — the normal condition in a hospital.
Clinical AI that must not be dangerous or fragile.	Restricted suggestions to stocked medicines; re-derived allergy conflicts locally; added a deterministic GSTG fallback; disclosed the source.	Cost: the assistant is narrower than an unconstrained one. Bought: an assistant that is safe when wrong and useful when offline.
Facilities lose connectivity.	Local/cloud database selection with an identical schema and seed, resolved in one place and covered by tests.	Cost: a configuration layer. Bought: a system usable during an outage.
A submission that could not have been assessed. All nine credentials published for the examiner failed against the live system.	Provisioned dedicated examiner accounts and verified them against the deployment before publishing.	Cost: an hour. Bought: the difference between a working submission and an unusable one.

20. Limitations

Stated plainly. Each is a bounded, known limitation rather than an unexamined gap.

No.	Limitation	Consequence	Reason
L-01	No live NIA or NHIA verification	Ghana Card and NHIS numbers are validated for format and internal consistency only	Requires an accredited integration agreement (C-03)
L-02	PACS is metadata-only	Orders, reports and accession numbers are managed; images are not stored or viewed	DICOM infrastructure beyond project resources (C-04)

L-03	Rate limiting is process-local	Throttling weakens across multiple serverless instances	Serverless constraint; shared store planned
L-04	DHIMS2 export is on-screen	Figures are computed correctly but must be re-keyed into DHIMS2	Format specification not obtained
L-05	Clinical assistant needs an Ollama host	Falls back to a three-condition rule engine — safe but narrow	Deliberate: no paid API, must work offline (C-05)
L-06	No offline-to-online synchronisation	Records created offline stay in the local database	Conflict resolution is a substantial design problem; scheduled in Phase 4
L-07	Two endpoints exceed the latency target	~1.1 s against an 800 ms target	Cross-region database round trip; remedy scheduled in Phase 1
L-08	No audit archival	The audit table grows without bound	Retention policy scheduled
L-09	Patient record merge not implemented	Duplicates are prevented but historical duplicates cannot be merged	Deferred requirement FR-PAT-07
L-10	No end-to-end browser test suite	Interface regressions rely on manual checking	Scheduled in Phase 1
L-11	Seeded data is deliberately small	Not a load-representative dataset	Chosen so every figure on screen is traceable to a row
L-12	Demonstration accounts share a password	Unacceptable in production	Forced password change scheduled

21. Maintenance Strategy

Presented in full in Maintenance_and_Evolution.pdf. Summarised here.

Category	Approach
Corrective	Severity by clinical consequence, not technical difficulty. Critical fixed within 24 hours. Every fix begins with a failing test, which is retained as a regression guard.
Adaptive	Tariffs, ICD codes and reporting formats are data rather than code, so annual regulatory change is a data update. Runtime and database upgrades are unobstructed by version-specific code.
Perfective	Improvements prioritised by clinical value, frequency, effort and risk, with automatic risk weighting for anything touching the access model or a transaction boundary.
Preventive	Weekly dependency audit, monthly updates, quarterly secret rotation, quarterly restore rehearsal, quarterly policy review, and an openly published technical debt register.

What makes it maintainable is architectural rather than procedural: invariants declared in one place, a type system that carries the database schema into the code, and tests that assert properties rather than only behaviours.

22. Future System Evolution and Enhancements

A five-phase roadmap is set out in Maintenance_and_Evolution.pdf 13, with a Gantt chart.

Phase	Period	Theme
1 — Hardening	Sep–Dec 2026	Close known debt: shared-store rate limiting, database co-location, pagination, browser tests, forced password change
2 — Completion	Dec 2026–Mar 2027	Deferred requirements: record merge, DHIMS2 export, discharge summaries, appointments, audit

		archival
3 — Integration	Apr–Dec 2027	National systems: NIA verification, NHIA eligibility and CLAIM-it, mobile money reconciliation, an HL7 FHIR façade
4 — Expansion	Oct 2027–Aug 2028	New domains: offline synchronisation, antenatal and immunisation, DICOM imaging, a ward-round mobile application
5 — Intelligence	Jun–Dec 2028	AI beyond prescribing: interaction checking, demand forecasting, claim rejection prediction, speech-to-text notes

The ordering is the argument. Hardening precedes completion because everything is built on it. Integration follows completion but is gated on agreements outside the team’s control. Intelligence is last because forecasting requires accumulated operational history — building it first would produce a system that forecast confidently and could not be trusted.

23. Conclusion

HealthEasy-G is a complete, deployed Hospital Management System that maintains one authoritative record per patient across every department of a Ghanaian health facility. It is live at <https://healtheasy-g.vercel.app>, backed by PostgreSQL, and every screen reads data from that database rather than from anything held in the browser.

All nine project objectives were met. The Master Patient Index prevents duplicates at the database level. A single clinical action fans out into the laboratory, the pharmacy, billing and NHIS claims without retyping. Nineteen roles and sixty-two permissions are enforced by the server on all twenty-four endpoints. Regulatory obligations — HeFRA licensing, NHIA G-DRG claims, DHIMS2 returns and the Data Protection Act — are addressed in the system’s behaviour rather than in its documentation. Dispensing and claim batching are atomic. The clinical assistant is restricted to stocked medicines, re-checks allergies itself, and degrades to a deterministic rule engine when offline. The system runs against a local database when the facility has no connectivity.

The most valuable outcome was not the feature set but what building it revealed. The system reached a point where it looked finished — every screen rendered, every module present — while authentication could be bypassed three different ways, identity was editable from the browser console, writes failed silently, and roughly nine hundred lines of fabricated data were standing in for an empty database. None of that was visible from the interface. It became visible only when the code was read carefully and when tests were written to assert properties rather than to confirm that screens appeared.

That experience produced the engineering position this project defends: **a claim about software is worth only as much as the evidence that can be produced for it.** The system claims that a system administrator cannot read patient records; 7.2 of the Testing Report shows the HTTP responses from the live deployment that prove it. It claims that dispensing cannot oversell stock; there is a test that drains a batch concurrently and demonstrates the rollback. It claims a defect log of seventeen items; sixteen are closed and the seventeenth is recorded as open with its cause, its measurement and its scheduled remedy.

Twelve limitations are stated openly rather than omitted, and each is bounded and scheduled. The system is not finished — hospital software never is — but it is honest about where it stands, and it is built so that the next person to change it can find the rule they need to change in one place.

24. References

24.1 Regulatory and Clinical Sources

1. Republic of Ghana. *Data Protection Act, 2012 (Act 843)*. Accra: Ghana Publishing Company.
2. Ministry of Health, Ghana. *Standard Treatment Guidelines*, 7th edition. Accra: Ghana National Drugs Programme.
3. National Health Insurance Authority. *Ghana Diagnosis-Related Groupings (G-DRG) Tariff Structure and Claims Submission Guidelines*. Accra: NHIA.
4. Ghana Health Service. *District Health Information Management System (DHIMS2) Reporting Requirements*. Accra: GHS.
5. Ghana Health Service. *Standard Operating Procedures for Health Information Management*. Accra: GHS.
6. Health Facilities Regulatory Agency. *Facility Licensing Requirements and Standards*. Accra: HeFRA.
7. World Health Organization. *International Statistical Classification of Diseases and Related Health Problems, 10th Revision (ICD-10)*. Geneva: WHO.
8. Gilboy, N., Tanabe, P., Travers, D. and Rosenau, A. M. *Emergency Severity Index (ESI): A Triage Tool for Emergency Department Care*, version 4. Rockville: Agency for Healthcare Research and Quality.

24.2 Software Engineering Sources

9. IEEE. *Std 830-1998: Recommended Practice for Software Requirements Specifications*. New York: IEEE.
10. Lientz, B. P. and Swanson, E. B. *Software Maintenance Management*. Reading: Addison-Wesley.
11. Sommerville, I. *Software Engineering*, 10th edition. Harlow: Pearson.
12. Fowler, M. *Patterns of Enterprise Application Architecture*. Boston: Addison-Wesley.
13. Newman, S. *Building Microservices*, 2nd edition. Sebastopol: O'Reilly Media.
14. OWASP Foundation. *OWASP Top Ten Web Application Security Risks*.
<https://owasp.org/www-project-top-ten/>
15. OWASP Foundation. *Authentication Cheat Sheet and Session Management Cheat Sheet*.
<https://cheatsheetseries.owasp.org/>
16. World Wide Web Consortium. *Web Content Accessibility Guidelines (WCAG) 2.1*.
<https://www.w3.org/TR/WCAG21/>

24.3 Technologies, Frameworks and Services Acknowledged

All third-party software used in this project is acknowledged below. Versions are recorded in package.json.

Software	Provider	Licence	Use
Next.js 16	Vercel Inc.	MIT	Application framework
React 19	Meta Platforms	MIT	User-interface library
TypeScript 5	Microsoft	Apache-2.0	Language
Prisma 5	Prisma Data Inc.	Apache-2.0	ORM and migrations
PostgreSQL	PostgreSQL Global Development Group	PostgreSQL Licence	Database
Tailwind CSS 4	Tailwind Labs	MIT	Styling
Radix UI	WorkOS	MIT	Accessible UI primitives
Tabler Icons	Tabler	MIT	Iconography
Iconify	Iconify	MIT	Icon framework
bcryptjs	Daniel Wirtz	MIT	Password hashing
ApexCharts	ApexCharts	MIT	Charting
Ollama JS SDK	Ollama	MIT	Local model access
tsx	esbuild-kit	MIT	TypeScript execution
Playwright	Microsoft	Apache-2.0	Browser automation for testing and diagram rendering
Mermaid	Mermaid contributors	MIT	Diagram rendering
Pandoc	John MacFarlane	GPL-2.0+	Document conversion
Manrope	Mikhail Sharanda	SIL OFL 1.1	Typeface

Newsreader	Production Type	SIL OFL 1.1	Typeface
Vercel	Vercel Inc.	Commercial (free tier)	Hosting
Neon	Neon Inc.	Commercial (free tier)	Managed PostgreSQL
GitHub Actions	GitHub / Microsoft	Commercial (free tier)	Continuous integration
AI used	Antigravity Claude Codex		

No third-party dataset was used. All seeded data is synthetic and was authored by the group; no real patient data appears anywhere in the system or in this documentation.

25. Appendices

Appendix A — Repository Structure

HealthEasy-G/

— .github/workflows/ci.yml	Continuous integration
— prisma/	
— schema.prisma	19 models
— migrations/	Versioned SQL migrations
— seed.ts	Complete database seed
— seed-examiner.ts	Examiner account provisioning
— resolve-datasource.ts	Local/cloud selection
— src/	
— app/	
— (DashboardLayout)/	33 application pages
— api/	24 route handlers
— components/	Shared and public-site components
— auth/	Sign-in
— page.tsx	Public landing page
— layout.tsx	Root layout, theming
— lib/	Domain services and security
— components/	UI primitives, RoleGuard, RBAC tree
— context/HMSContext.tsx	Client state
— proxy.ts	Security perimeter
— tests/	53 automated tests
— scripts/	Database and documentation tooling
— docs/	Documentation sources
— README.md	Examiner quick guide

Appendix B — API Endpoint Reference

Endpoint	Methods	Purpose
/api/auth/login	POST	Authenticate and issue a session
/api/auth/logout	POST	End a session
/api/auth/session	GET	Return the current staff profile
/api/patients	GET, POST	Master Patient Index
/api/queues	GET, POST, PATCH	Patient flow
/api/vitals	GET, POST	Triage observations
/api/encounters	GET, POST	Clinical consultations
/api/lab-orders	GET, POST, PATCH	Laboratory workflow
/api/lab-catalogue	GET, POST	Test catalogue
/api/radiology	GET, POST	Imaging orders and reports
/api/beds	GET, PATCH	Ward bed management
/api/mar	GET, POST, PATCH	Medication administration
/api/pharmacy	GET, PATCH	Drug stock
/api/pharmacy/dispense	GET, POST	Dispensing with stock deduction
/api/billing	GET, POST, PATCH	Invoicing and payment
/api/nhis-claims	GET, POST	Claim lines
/api/nhis-batches	GET, POST, PATCH	Claim batching
/api/inventory	GET, POST	Stores
/api/facilities	GET, POST, PATCH	Facility management
/api/staff	GET, POST	Staff directory
/api/stats	GET	Aggregate statistics, no identifiers
/api/dhims2	GET, POST	DHIMS2 monthly return
/api/audit-logs	GET, POST	Audit trail
/api/ai-assistant	POST	Clinical decision support

Appendix C — Role and Permission Summary

Nineteen roles across four hierarchy levels, holding sixty-two permissions.

Level	Roles
1	Super Admin
2	Hospital Director, System Auditor
3	Hospital Admin, OPD / Medical Records, Doctor, Nurse, Ward Manager, Theatre Nurse, Laboratory Technician, Radiographer, Radiologist, Pharmacist, Cashier
4	Finance Officer, Claims Officer, HR Officer, Procurement Officer, Store Keeper

Each role definition carries allowedRoutes, permissions and an explicit cannot list. The cannot entries are not decorative: the Super Admin's — that it may not access patient records — is enforced and tested.

Appendix D — Environment Variables

Variable	Required	Purpose
DATABASE_TARGET	Yes	local or cloud
DATABASE_URL_LOCAL	If local	Offline PostgreSQL connection string
DATABASE_URL_CLOUD	If cloud	Online PostgreSQL connection string
DATABASE_URL	Optional	Overrides both; used by CI and hosting
SESSION_SECRET	Yes	Session signing key, ≥32 characters
SESSION_MAX_AGE_SECONDS	No	Session lifetime, default 28800
OLLAMA_MODEL	No	Clinical assistant model
OLLAMA_TIMEOUT_MS	No	Assistant timeout, default 15000
NEXT_PUBLIC_FACILITY_CODE	No	Default facility code

Appendix E — Commands

Command	Purpose
<code>npm run dev</code>	Development server
<code>npm run build</code>	Production build
<code>npm run typecheck</code>	TypeScript, no emit
<code>npm test</code>	53 automated tests
<code>npm run db:setup:local</code>	Create and seed the offline database
<code>npm run db:setup:cloud</code>	Create and seed the online database
<code>npm run db:studio</code>	Database browser
<code>npm run db:seed:examiner</code>	Provision examiner accounts
<code>node scripts/db-inspect.mjs</code>	Row counts and column types
<code>node scripts/build-docs.mjs</code>	Rebuild this documentation set

Appendix F — Test Execution Summary

i tests 53

i suites 14

i pass 53

i fail 0

i duration_ms 1549.7849

Full output, the live access-control matrix, performance measurements and the complete defect log appear in `Testing_Report.pdf`.

Appendix G — Live Database Contents at Submission

Table	Rows	Table	Rows
facilityBranch	3	radiologyOrder	2
userStaff	22	pharmacyBatch	6
patient	5	dispenseRecord	1
queueItem	3	billingInvoice	2
vitalSigns	3	nHISClaimLine	2
eMREncounter	2	nHISClaimBatch	0
inpatientBed	5	medicationAdministrationRecord	3
labOrder	3	dhimsMonthlyReturn	1
labTestCatalogue	10	inventoryStoreItem	5
		auditLog	19

nHISClaimBatch is empty by design: a batch is created by a Claims Officer action, not seeded. The dataset is deliberately small so that every figure displayed can be traced to a specific row.